

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 1 頁，共 15 頁

單複選題及情境題組題 共 40 題 (佔 100%)

D	1. X 公司為在中華民國註冊登記之公司，該公司將於在 2024 年導入資安管理制度。並預計於 2025 年第一季通過國際資安驗證，請問下列何項制度最適合 X 公司做為導入資訊安全管理制度依循之參考？ (A) ISO/IEC 27001 : 2013 (B) ISO/IEC 27004 : 2016 (C) ISO/IEC 20000 : 2018 (D) ISO/IEC 27001 : 2022
C	2. 下列何項「不」是帳號管理的安全政策？ (A) 定期檢視超過一定期間未登入之使用者帳號 (B) 定期檢視管理者帳號 (C) 要求使用者密碼須為複雜性密碼 (D) 依申請期限，關閉臨時帳號
B	3. 導入下列何者措施，其主要目的「不」是提升機密性？ (A) 在內部重要網段增設防火牆 (B) 導入主機負載平衡系統 (C) 導入資料加密系統 (D) 限制機密資料僅少數人員可以存取
B C D	4. 2024/05/13 韓國警察廳國家搜查本部發出聲明，韓國法院近 1TB 資料遭竊，是該國司法單位首度遭到敵對駭客攻擊。攻擊者至少從 2021 年 1 月 7 日就入侵該國法院，但因記錄過期遭到清除，無法確認是否早已滲透，亦無從得知事故原因。借鑒此案例，若依據我國「資通安全責任等級分級辦法」與「各機關資通安全事件通報及應變處理作業程序」等所規定，資安事件跡證保存之規劃下列那些最正確？（複選） (A) 日誌留存依機關等級而異，等級「普」至少六個月而等級「高」為兩年 (B) 日誌保存範圍涵蓋各項資通系統，與資通及防護設備日誌紀錄 (C) 日誌宜保存項目為作業系統日誌、網站日誌、應用

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 2 頁，共 15 頁

	程式日誌與登入日誌 (D) 日誌內容宜應含事件類型、發生時間與位置，及事件相關之使用者身分識別等資訊
B	5. 【題組 1】情境如附圖所示。依據該公務機關之業務特性對於法規遵循事項所應遵循之法律規範，試問下列何項敘述較為合適？ 某資通安全責任等級 A 級之公務機關主要業務係辦理全國有關全民健康保險之業務活動，今為了符合國內資通安全有關法規之遵循，因此實施了一系列資訊安全有關之作為。 (A) 應遵循智慧財產權法以及資通安全管理法之規定 (B) 應遵循個人資料保護法以及資通安全管理法之規定 (C) 應遵循智慧財產權法以及個人資料保護法之規定 (D) 應遵循著作權法以及個人資料保護法之規定
C	6. 【題組 1】情境如附圖所示。試問該機關主責資通安全有關事項之承辦窗口所實施之一系列有關資訊安全作為，試問下列何項敘述正確？ 某資通安全責任等級 A 級之公務機關主要業務係辦理全國有關全民健康保險之業務活動，今為了符合國內資通安全有關法規之遵循，因此實施了一系列資訊安全有關之作為。 (A) 每年辦理一次內部資通安全稽核 (B) 每二年辦理一次資通安全健診活動 (C) 資通安全專職人員配置四人 (D) 非核心資通系統導入 ISO 27001 資訊安全管理系統標準
A	7. 【題組 1】情境如附圖所示。試問該機關主責資通安全有關事項之承辦窗口所規畫導入與該機關主要業務特性有關之 ISO 國際標準，下列較為適宜？ 某資通安全責任等級 A 級之公務機關主要業務係辦理全國有關全民健康保險之業務活動，今為了符合國內資通安全有關法規之遵循，因此實施了一系列資訊安全有關之作為。 (A) 導入 ISO 27001 及 ISO 27701 國際標準

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 3 頁，共 15 頁

	(B) 導入 ISO 27001 及 ISO 45000 國際標準 (C) 導入 ISO 27001 及 ISO 17025 國際標準 (D) 導入 ISO 27001 及 ISO 50001 國際標準
A C D	8. 【題組 1】情境如附圖所示。該機關決定於 3 個月後正式導入 ISO 27001 資訊安全管理系統，因此，主責資通安全有關事項之承辦窗口正評估 ISO 27001 資訊安全管理系統導入範圍，依該機關主要業務特性，試問下列哪些系統應納入 ISO 27001 資訊安全管理系統的「導入範圍」？（複選） 某資通安全責任等級 A 級之公務機關主要業務係辦理全國有關全民健康保險之業務活動，今為了符合國內資通安全有關法規之遵循，因此實施了一系列資訊安全有關之作為。 (A) 全民健保納保系統 (B) 人員請假系統 (C) 全民健保退保系統 (D) 全民健保查詢系統
D	9. 關於縱深防禦（Defense in Depth）的敘述，下列何者錯誤？ (A) 係透過應用多種的安全機制來建立一系列的安全屏障 (B) 可以防止、延遲或阻止攻擊行為 (C) 主要安全機制可以包含邊界防禦、身份驗證和授權、主機和端點保護、應用程式保護、資料保護、安全監控與事件回應等機制 (D) 可以完全取代資安託管服務
A	10. 公司採用聲紋辨識器作為門禁控制措施，因員工感冒，導致其被拒絕進入，這種現象稱為下列何項？ (A) False reject (B) False accept (C) Type-II error (D) CER
B	11. 職務區隔及責任範圍區隔，旨在分隔不同個人間相互衝突之職務，以防止一個人獨自執行潛在衝突的職務。下列何者的

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 4 頁，共 15 頁

	應用情境較「不」適當？ (A) 啟動、核可及執行變更 (B) 使用及列印應用程式說明文件 (C) 設計、實作及審視程式碼 (D) 請求、核可及實作存取權限
A C D	12. 下列哪些措施的採用「有助於」職務區隔（Separation of Duties, SOD）控制措施有效的施行？（複選） (A) 職務定期輪調 (B) 多因素驗證（MFA） (C) 以角色為基礎的存取控制（RBAC） (D) 定期實施權限審查
B	13. 【題組 2】情境如附圖所示。公司規畫於台南工廠設立備援機房，以便於新竹主機房失效時，即時自動啟動備援，請問備援資料庫最長可以設定多久與主要資料庫同步一次？ K 公司為總部設立新竹之汽車零組件製造商，公司股票亦已於臺灣證券交易所上市交易。此外公司已在 2023 年初通過 ISO 27001 驗證，目前公司主要系統可用性目標為：可接受中斷時間為 8 小時以內；資料完整性目標為：資料流失可接受時間為 8 小時以內。 (A) 5 小時 (B) 7 小時 (C) 9 小時 (D) 11 小時
D	14. 【題組 2】情境如附圖所示。K 公司終於承接到美國 T 公司的大訂單，但是 T 公司要求可遠端連入 K 公司系統查詢訂單及庫存資訊，請問下列做法何項最「不」適當？ K 公司為總部設立新竹之汽車零組件製造商，公司股票亦已於臺灣證券交易所上市交易。此外公司已在 2023 年初通過 ISO 27001 驗證，目前公司主要系統可用性目標為：可接受中斷時間為 8 小時以內；資料完整性目標為：資料流失可接受時間為 8 小時以內。 (A) 要求 T 公司以 VPN 方式進入公司 (B) 限制該帳號查詢權限

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 5 頁，共 15 頁

	(C) 要求定期更改密碼 (D) 業務單位於客戶不需使用時，仍應維持半年可用，以避免影響業務運作
C	15. 【題組 2】情境如附圖所示。K 公司為保護客戶重要機密資料，擬導入加密管理系統，請問於選擇加密管理系統時，下列何者為此階段「非」必要評估項目？ K 公司為總部設立新竹之汽車零組件製造商，公司股票亦已於臺灣證券交易所上市交易。此外公司已在 2023 年初通過 ISO 27001 驗證，目前公司主要系統可用性目標為：可接受中斷時間為 8 小時以內；資料完整性目標為：資料流失可接受時間為 8 小時以內。 (A) 系統功能需求評估 (B) 導入方式評估 (C) 備份機制評估 (D) 安全要求評估
A C 、 A C D	16. 【題組 2】情境如附圖所示。K 公司於 2023 年底進行 ISO27001 資訊安全管理系統年度管理審查，考量法規遵循時，下列哪些為必要考量項目？（複選） K 公司為總部設立新竹之汽車零組件製造商，公司股票亦已於臺灣證券交易所上市交易。此外公司已在 2023 年初通過 ISO 27001 驗證，目前公司主要系統可用性目標為：可接受中斷時間為 8 小時以內；資料完整性目標為：資料流失可接受時間為 8 小時以內。 (A) 個人資料保護法 (B) 資通安全管理法 (C) 客戶合約之資安要求 (D) 上市上櫃公司資通安全管控指引
A	17. 某公司新增了一業務型態，員工（20 員，每員配置筆電乙部以及隨身硬碟乙顆）必須至客戶端長期駐點處理有關受託業務，並於客戶端透過網際網路連線回公司內部網路處裡公司相關業務，為了降低此一新增業務型態所衍伸出來的資安風險，該公司正評估採取有效的控制措施來降低此風險，請問下列控制措施何項較無法降低此風險？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 6 頁，共 15 頁

	(A) 網站應用防火牆 (Web Application Firewall , WAF) (B) 端點偵測及應變機制 (Endpoint Detection and Response , EDR) (C) 虛擬私有網路 (Virtual Private Network , VPN) (D) 防毒軟體 (Antivirus Software)
A	18. 關於網路安全架構中的基本要素，下列何項敘述「有誤」？ (A) 包含雲端儲存設備 (B) 包含防火牆設備 (C) 包含惡意軟體偵測設備 (D) 包含虛擬私人網路 (VPN) 設備
B	19. 規劃端點安全架構時，納入端點偵測及應變機制 (Endpoint Detection and Response , EDR) 的最主要目的之敘述，下列何者正確？ (A) 防禦網路入侵行為 (B) 監控端點入侵行為 (C) 管理端點網路流量 (D) 管理端點資料傳輸
A B C	20. 關於零信任架構 (ZTA) 的敘述，下列哪些正確？ (複選) (A) 對於資源的存取要求，以每次連線為基礎去許可 (B) 對於存取的要求，每次是以最小權限為原則去執行 (C) 允許存取之前，所有的資源的身分鑑別與授權機制，是依監控結果動態決定 (D) 是一種以邊界為基礎的資安架構，一旦連線通過了認證就值得信任
C	21. 【題組 3】情境如附圖所示。假設公司認為研發部門的資料為其重要的營業祕密，故不允許外部及其他部門存取研發部門的資料，R1 與 R2 部門間亦不允許互相存取。但因研發需求，開放研發部門的員工可以上網，不過所有的流量需要集中由據點 B 上網，試問下列何種措施較「不」合適？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 7 頁，共 15 頁

	某公司為我國一先進技術的開發商，該公司主要據點 A 與 B 分散在國內兩地，該公司十分重視資訊安全及品質管理，先前已通過 ISO 9001、ISO 14001 等相關標準的驗證。據點 A 主要包含的業務 S 與研發 R1 兩個部門，據點 B 主要包含管理部門 A 與研發 R2 兩個部門，資訊相關的事務由管理部門 A 負責。 (A) 各部門切割成獨立的網段 (B) 兩據點間透過 Site to Site 的 VPN 連線 (C) 開放所有員工透過 SSL VPN 從外部連回公司讀取研發資料 (D) 將據點 A 的上網流量透過 VPN 通道引導到據點 B
D	22. 【題組 3】情境如附圖所示。業務部門員工因為工作需求，常需於公司外存取員工個人在部門辦公室內桌上型電腦的資料，為求慎重，公司希望能留下相關的存取記錄，並盡量強化安全，試問下列何種措施最為合適？ 某公司為我國一先進技術的開發商，該公司主要據點 A 與 B 分散在國內兩地，該公司十分重視資訊安全及品質管理，先前已通過 ISO 9001、ISO 14001 等相關標準的驗證。據點 A 主要包含的業務 S 與研發 R1 兩個部門，據點 B 主要包含管理部門 A 與研發 R2 兩個部門，資訊相關的事務由管理部門 A 負責。 (A) 開放員工使用 RDP 連回自己的桌上型電腦 (B) 開放員工使用 TeamViewer 連回自己的桌上型電腦 (C) 建置 VPN Server，讓員工連回其在部門辦公室內桌上型電腦 (D) 建置 VPN Server，讓員工透過 VPN 連回公司，再於公司內隔離的 VPN 網段中，透過 RDP 連回自己的桌上型電腦
B	23. 【題組 3】情境如附圖所示。由於業務部門員工常需透過公司配發的筆記型電腦，在公司外進行工作，為避免因設備遺失導致資料外流，試問下列何種措施最為合適？ 某公司為我國一先進技術的開發商，該公司主要據點 A 與 B 分散在國內兩地，該公司十分重視資訊安全及品質管理，先前已通過 ISO 9001、ISO 14001 等相關標準的驗證。據點 A 主要包含的業務 S 與研發 R1 兩個部門，據點 B 主要包含管理部門 A 與研發 R2 兩個部門，資訊相關的事務由管理部門 A 負責。 (A) 於筆記型電腦的 BIOS 設定並啟用開機密碼

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 8 頁，共 15 頁

	(B) 於筆記型電腦設定並啟用 BitLocker 與使用者密碼登入 (C) 於筆記型電腦的作業系統設定並啟用 PIN 碼登入 (D) 於筆記型電腦的作業系統設定並啟用 Windows Hello 登入
A D	24. 【題組 3】情境如附圖所示。由於目前公司仍缺乏資訊安全管理相關的驗證，最高管理階層希望採取相關措施，試問下列何種措施較為合適？（複選） 某公司為我國一先進技術的開發商，該公司主要據點 A 與 B 分散在國內兩地，該公司十分重視資訊安全及品質管理，先前已通過 ISO 9001、ISO 14001 等相關標準的驗證。據點 A 主要包含的業務 S 與研發 R1 兩個部門，據點 B 主要包含管理部門 A 與研發 R2 兩個部門，資訊相關的事務由管理部門 A 負責。 (A) 由於資訊相關的事務由管理部門 A 負責，故優先考慮由其導入 ISO 27001:2022 的驗證 (B) 考慮公司中相關人員對 ISO 27001:2013 較為熟悉，先導入 2013 版，日後再進行改版驗證 (C) 由於公司也有個資保護管理制度驗證的需求，故直接導入全公司 ISO 27701:2019 的驗證 (D) 由於公司也有個資保護管理制度驗證的需求，故直接導入全公司 ISO 27001:2022 的驗證，再導入 ISO 27701:2019 的驗證
C	25. 與資訊安全風險分析相關議題的敘述，下列何者錯誤？ (A) 主管機關公文來函要求事項，可納入風險分析的參考 (B) 法律法規適用的要求事項，可納入風險分析的參考 (C) 客戶合約的要求，可以不用納入風險分析的參考 (D) 組織本身內部與外部的議題，可納入風險分析的參考
B	26. 風險分析其中一個功能是利用量化計算公式估算並詮釋風險程度，身為組織資通安全主管的您，正進行組織官網系統的安全風險評估，現在的情境為估算一個 20 年才會出現一次的地震，將可能造成之風險值為下列何項？（其中「曝露

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 9 頁，共 15 頁

	因子」(E.F)=25%、資通系統價值=50 萬元。) (A) 125000 (B) 6250 (C) 2500000 (D) 0 (無風險)
A	27. 如附圖所示的內容，比較類似下列何種的風險分析類型？ 您是組織的資通安全主管，發現有一些資通安全風險正在對你的組織構成威脅，於是您完成這些風險因子的揭露程度之衡量，認為風險因子具備很大的影響潛力，當所有其他不確定因子保持在基準線時，每個因子的不確定性對所考量的對象影響程度。 (A) 敏感度分析 (Sensitivity Analysis) (B) 故障樹分析 (Fault Tree Analysis) (C) 因果分析 (Cause-consequence Analysis) (D) 情境分析 (Scenario Analysis)
C D	28. 一般常見風險評鑑流程報包括：識別背景、風險辨識、風險評估與分析、風險回應、風險監督；下列敘述哪些屬於「風險評估與分析」階段？(複選) (A) 執行風險評鑑作業發現 68 個風險項目 (B) 已確認 55 個低風險項目，屬風險可接受範圍，決定維持現狀不做改變 (C) 將風險項目區分為 3 個高風險項目、10 個中風險項目、55 個低風險項目 (D) 使用定量的方法，將風險進行排序
C	29. 【題組 4】情境如附圖所示。該公司風險管理作業程序之流程包含：a.風險分析、b.風險排序、c.風險識別、d.識別背景資訊、e.風險處理，請問下列何項流程較為正確？ S 公司為設立於中華民國之消費性電子產品製造商，並同時於台灣及歐洲地區架設網站對一般民眾販售消費性電子產品，且公司網路購物之收益占公司整體利益 90%以上。公司已通過 ISO 27001 驗證，並於 2023 年 12 月依照所訂定之程序完成風險評估作業。目前公司對於對外服務之網站、系統設定最大可中斷時間為 12 小時。

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 10 頁，共 15 頁

	(A) abcde (B) edcba (C) dcabe (D) cdbae
D	30. 【題組 4】情境如附圖所示。若 S 公司風險評估後，發現在歐洲地區法令遵循風險過高，決定關閉該地區的銷售網站，請問此項做法屬於下列何項風險措施？ S 公司為設立於中華民國之消費性電子產品製造商，並同時於台灣及歐洲地區架設網站對一般民眾販售消費性電子產品，且公司網路購物之收益占公司整體利益 90%以上。公司已通過 ISO 27001 驗證，並於 2023 年 12 月依照所訂定之程序完成風險評估作業。目前公司對於對外服務之網站、系統設定最大可中斷時間為 12 小時。 (A) 風險保留 (Risk Retention) (B) 風險降低 (Risk Reduction) (C) 風險轉移 (Risk Transfer) (D) 風險避免 (Risk Avoidance)
B	31. 【題組 4】情境如附圖所示。若於 S 公司網購網站上架產品之重要客戶於 2024 年 2 月要求，其網購網站服務中斷不得超過 8 小時。若公司判斷此為重大風險事件，請為下列何者作法較正確？ S 公司為設立於中華民國之消費性電子產品製造商，並同時於台灣及歐洲地區架設網站對一般民眾販售消費性電子產品，且公司網路購物之收益占公司整體利益 90%以上。公司已通過 ISO 27001 驗證，並於 2023 年 12 月依照所訂定之程序完成風險評估作業。目前公司對於對外服務之網站、系統設定最大可中斷時間為 12 小時。 (A) 資訊單位自行決定，直接調配資源改善網購網站之不可中斷時間至 8 小時以內 (B) 立即進行風險評估，依風險評估結果辦理相關事宜 (C) 直接告知客戶本公司網購網站最大可中斷時間為 12 小時，請其接受 (D) 暫時擱置，於年底風險評估後，再依風險評估結果辦理相關事宜

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 11 頁，共 15 頁

B C	32. 【題組 4】情境如附圖所示。若 S 公司進行風險評估時，發現網購系統有重大資安漏洞，可能造成大量客戶及廠商資料外洩，請問下列哪些風險處理措施，對該公司而言是較適合且可行的作法？（複選） S 公司為設立於中華民國之消費性電子產品製造商，並同時於台灣及歐洲地區架設網站對一般民眾販售消費性電子產品，且公司網路購物之收益占公司整體利益 90%以上。公司已通過 ISO 27001 驗證，並於 2023 年 12 月依照所訂定之程序完成風險評估作業。目前公司對於對外服務之網站、系統設定最大可中斷時間為 12 小時。 (A) 風險保留 (Risk Retention) (B) 風險降低 (Risk Reduction) (C) 風險轉移 (Risk Transfer) (D) 風險避免 (Risk Avoidance)
D	33. 公司規定於風險回應後 3 個月，須對該項風險進行風險再評估。當風險再評估時發現該風險並未如預期降至風險胃納 (Risk appetite) 之內。如附圖所示的項目之中，哪些是可能的原因？ 1. 風險回應規劃不當 2. 風險回應尚未執行完成 3. 風險回應未落實執行 (A) 1、2 (B) 2、3 (C) 1、3 (D) 1、2、3
C	34. 關於 ISO 31000 風險管理原理及指導綱要之敘述，下列何項錯誤？ (A) 可做為任何組織尋求風險管理的明確指南 (B) 提供風險管理的原則與通用的實施指導準則

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 12 頁，共 15 頁

	(C) 是風險管理的國際標準，可提供企業組織進行驗證 (D) 可幫助企業組織進行風險分析和風險評估
C	35. 依據 CNS 31000:2021 有關風險處理所涉及迭代 (Iteration) 過程之敘述，下列何項「有誤」？ (A) 選擇風險處理之選項 (B) 規劃與實施風險處理 (C) 評鑑風險處理之大小 (D) 決定殘餘風險是否可接受
A C	36. 行政院及所屬各機關風險管理及危機處理作業原則，下列何項「不」是風險管理步驟之持續循環過程？（複選） (A) 需建立財務背景資料調查 (B) 需完成評估風險 (C) 每兩年完成一次監督及檢討 (D) 傳遞資訊、溝通及諮詢
C	37. 【題組 5】情境如附圖所示。若公司規定超出風險胃納才須進行風險處理，請問依規定須進行處理之風險項目，不可能出現下列何項風險回應方式？

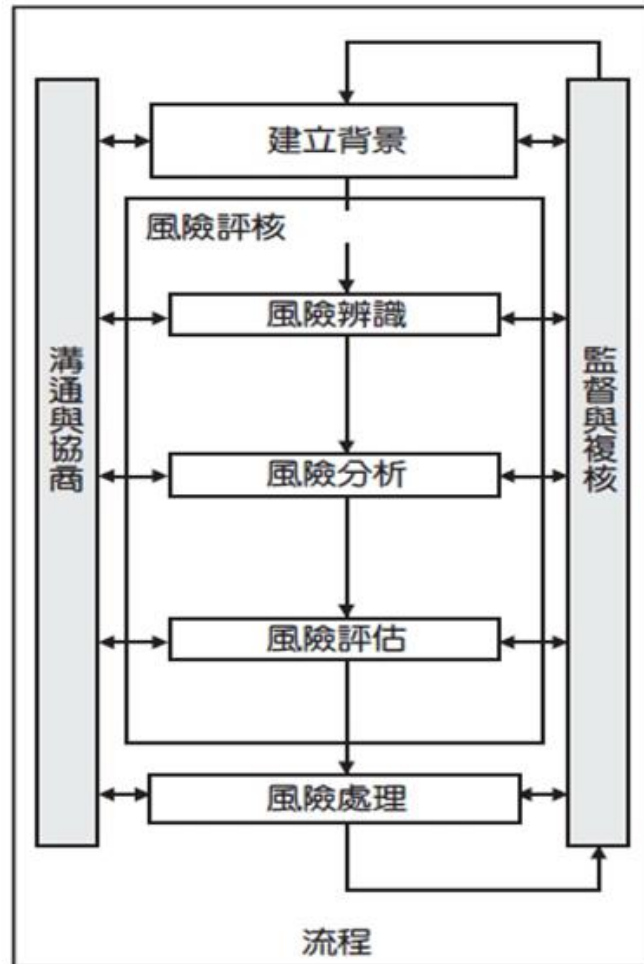
113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 13 頁，共 15 頁

M 公司為國內股票上市公司，從事國內資安軟體開發銷售相關業務，已通過 ISO 27001:2013 之驗證，並持續維持證照有效。公司並於每年 3 月進行年度風險評鑑作業，並規定執行風險回應後最遲須於 2 個月內確認有效，今年亦以依照預定時程完成相關作業。



- (A) 風險緩解 (Risk mitigation)
- (B) 風險規避 (Risk avoidance)
- (C) 風險保留 (Risk retention)
- (D) 風險分擔 (Risk sharing)

- C 38. 【題組 5】情境如附圖所示。承上題，若 M 公司於今年 4 月底接獲政府標案，預計於今年 8 月初正式將產品販售給政府一級機關，公司認為此有重大業務影響，並提早於 5 月進行此項業務改變的風險評鑑。請問公司會發現需要臨時進行此項風險評鑑是基於哪項公司流程所產生的作用？

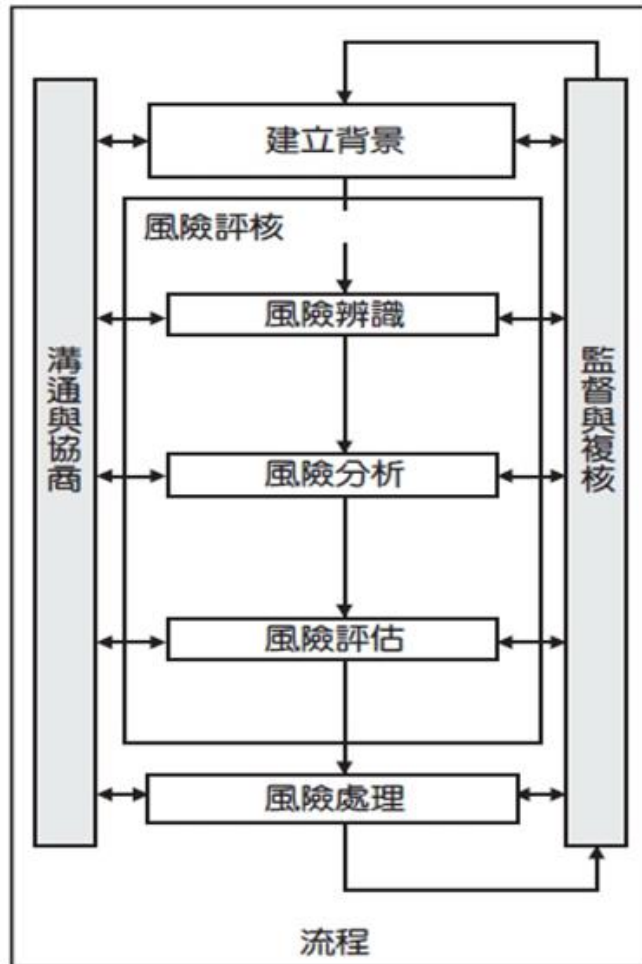
113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 14 頁，共 15 頁

M 公司為國內股票上市公司，從事國內資安軟體開發銷售相關業務，已通過 ISO 27001:2013 之驗證，並持續維持證照有效。公司並於每年 3 月進行年度風險評鑑作業，並規定執行風險回應後最遲須於 2 個月內確認有效，今年亦以依照預定時程完成相關作業。



- (A) 建立背景
- (B) 風險辨識
- (C) 監督與複核
- (D) 風險分析

- A 39. 【題組 5】情境如附圖所示。承上題，M 公司與 A 公司簽訂之合約內容要求 M 公司必須符合資通安全法。同時並規定產品正式販售前 M 公司必須符合合約所有規範事項。公司進行所述之風險評鑑辨識出法遵風險，並規劃相關風險回應，請問應何時完成風險回應並確認有效？

113 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：113 年 08 月 10 日

第 15 頁，共 15 頁

	M 公司為國內股票上市公司，從事國內資安軟硬體開發銷售相關業務，已通過 ISO 27001:2013 之驗證，並持續維持證照有效。公司並於每年 3 月進行年度風險評鑑作業，並規定執行風險回應後最遲須於 2 個月內確認有效，今年亦以依照預定時程完成相關作業。 (A) 6 月執行風險回應，7 月確認風險回應有效 (B) 6 月執行風險回應，8 月確認風險回應有效 (C) 7 月執行風險回應，9 月確認風險回應有效 (D) 8 月執行風險回應，10 月確認風險回應有效
A B D	40. 【題組 5】情境如附圖所示。承上題，請問 M 公司於今年初進行年度風險評鑑時，在建立背景流程，識別背景資訊時，下列哪些項目宜列入考量？（複選） M 公司為國內股票上市公司，從事國內資安軟硬體開發銷售相關業務，已通過 ISO 27001:2013 之驗證，並持續維持證照有效。公司並於每年 3 月進行年度風險評鑑作業，並規定執行風險回應後最遲須於 2 個月內確認有效，今年亦以依照預定時程完成相關作業。 (A) 上市上櫃公司資通安全管控指引 (B) 資通安全管理法 (C) GDPR（General Data Protection Regulation） (D) ISO 27001：2013